

CO-2 ASSESSMENT TOOL-01

Reddy Dorniya

19237206

Question 1

Analyze the Nmap report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures.

Nmap (Network Mapper) is one of the most widely used ethical hacking tools for network discovery and security auditing. It helps security professionals identify active hosts, open ports, running services, service versions, and operating systems. In this report, the target system **192.168.1.10** has three important open ports: **22 (SSH)**, **80 (HTTP)**, and **3306 (MySQL)**. The scan also reveals the operating system and service versions. Although these services are necessary for normal business operations, they also present security risks if not properly secured.

1. SSH Service (Port 22)

SSH (Secure Shell) is used to remotely access and manage systems securely.

Security Risks:

- Weak passwords may allow brute-force attacks.
- Default usernames such as "admin" or "root" make attacks easier.
- Older SSH versions may contain known vulnerabilities.
- If attackers obtain login credentials, they can gain full access to the server.

Possible Exploitation:

An attacker may use password-guessing tools or stolen credentials to log into the server. Once access is gained, they can steal sensitive files, install malware, modify system configurations, or create backdoor accounts for future access.

2. HTTP Service (Port 80)

HTTP is used to host websites and web applications.

Security Risks:

- Data transmitted over HTTP is not encrypted.
- Sensitive information such as usernames and passwords can be intercepted.
- Web applications may contain vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), Directory Traversal, or Remote Code Execution.

Possible Exploitation:

Attackers can exploit vulnerable web applications to steal user information, upload malicious files, deface websites, or gain administrative privileges.

3. MySQL Service (Port 3306)

MySQL is a database server used to store organizational data.

Security Risks:

- Weak database passwords.
- Default user accounts.
- Outdated MySQL software.
- Database service exposed directly to the internet.

Possible Exploitation:

An attacker may gain unauthorized access to the database, steal confidential information, modify records, delete important data, or create malicious database users.

Operating System and Service Version Detection

The scan also identifies the operating system and software versions.

Security Risk:

This information helps attackers identify known vulnerabilities and launch targeted attacks using publicly available exploits.

Recommended Security Measures

To secure the target system, the organization should:

- Disable unnecessary services and close unused ports.
- Use strong passwords and Multi-Factor Authentication (MFA).
- Disable root login for SSH and use SSH key authentication.

- Replace HTTP with HTTPS using SSL/TLS certificates.
- Regularly update and patch all software.
- Restrict MySQL access to trusted hosts only.
- Enable firewalls to block unauthorized traffic.
- Install Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS).
- Perform regular vulnerability scans and security audits.
- Continuously monitor server logs for suspicious activities.

Conclusion

The Nmap scan provides valuable information about the target system's network services and operating system. If these services are not properly secured, attackers can exploit them to gain unauthorized access, steal sensitive information, or disrupt business operations. Proper security configurations, timely software updates, strong authentication, firewalls, and continuous monitoring significantly reduce these risks.

Question 2

Analyze the GoPhish report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies.

GoPhish is an open-source phishing simulation tool used to evaluate employee awareness of phishing attacks. According to the report, **40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment.** These results indicate that employees are highly vulnerable to phishing and social engineering attacks.

Security Weaknesses Identified

1. Employees Clicked the Phishing Link (40%)

This shows that many employees could not identify fake or suspicious emails.

Risks:

- Malware infection
- Redirection to fake websites

- Unauthorized downloads
- Credential theft

2. Employees Entered Their Login Credentials (20%)

Employees trusted fake login pages and disclosed their usernames and passwords.

Risks:

- Unauthorized system access
- Account compromise
- Data breaches
- Identity theft
- Financial losses

3. Downloading Malicious Attachments

Some employees downloaded infected files attached to phishing emails.

Risks:

- Ransomware infection
- Spyware installation
- Keylogger attacks
- Remote Access Trojan (RAT) installation
- Complete system compromise

Overall Security Weaknesses

The report highlights several organizational weaknesses:

- Lack of phishing awareness.
- Insufficient cybersecurity training.
- Weak password management.
- Poor email verification practices.
- Lack of Multi-Factor Authentication (MFA).
- Inadequate email filtering systems.

Recommended User Awareness Programs

The organization should conduct regular cybersecurity awareness training that teaches employees how to:

- Identify phishing emails.
- Verify email senders.
- Avoid clicking suspicious links.
- Recognize fake websites.
- Report suspicious emails immediately.

The company should also perform periodic phishing simulation exercises using tools like GoPhish to measure employee awareness and improve their ability to recognize phishing attempts.

Recommended Email Security Controls

To reduce phishing attacks, the organization should implement:

- Secure Email Gateways (SEG).
- Spam filtering.
- Attachment scanning using antivirus software.
- URL filtering to block malicious websites.
- SPF (Sender Policy Framework).
- DKIM (DomainKeys Identified Mail).
- DMARC (Domain-based Message Authentication, Reporting and Conformance).
- Endpoint Detection and Response (EDR) solutions.

Recommended Organizational Policies

The organization should establish:

- Strong password policies.
- Mandatory Multi-Factor Authentication.
- Acceptable Use Policy (AUP).
- Incident Reporting Policy.
- Regular cybersecurity awareness programs.

- Periodic security audits and phishing assessments.

Conclusion

The GoPhish report demonstrates that employees are the weakest link in organizational security. Many users failed to recognize phishing emails and disclosed sensitive information. Continuous cybersecurity training, stronger email security controls, Multi-Factor Authentication, and well-defined organizational policies can significantly reduce the success of phishing and other social engineering attacks.

Question 3

Analyze the DNS Zone Transfer (AXFR) report. Explain the security implications of the exposed information, discuss how attackers could exploit these findings, and recommend best practices to secure the DNS infrastructure.

DNS (Domain Name System) translates domain names into IP addresses and is an essential component of internet communication. A DNS Zone Transfer (AXFR) is used to synchronize DNS records between primary and secondary DNS servers. However, if zone transfers are not properly restricted, unauthorized users can obtain the complete DNS database of an organization.

In this report, the Dig tool successfully performed a DNS Zone Transfer, revealing internal hostnames, mail servers, and DNS records. This indicates that the DNS server is misconfigured and allows unauthorized AXFR requests.

Security Implications

The exposed DNS information may include:

- Internal hostnames.
- IP addresses.
- Mail server details.
- Name server records.
- Web server information.
- Subdomains.
- DNS configurations.

This information helps attackers understand the organization's internal network structure and identify valuable targets.

How Attackers Can Exploit the Information

Attackers can use the exposed DNS records to:

- Perform detailed network reconnaissance.
- Identify web servers, mail servers, VPN gateways, and database servers.
- Launch targeted phishing attacks against employees.
- Exploit vulnerable systems identified from the DNS records.
- Conduct brute-force attacks against discovered services.
- Plan future cyberattacks more effectively.

Best Practices to Secure DNS Infrastructure

Organizations should implement the following security measures:

- Restrict DNS Zone Transfers only to authorized secondary DNS servers.
- Disable public AXFR requests.
- Configure Access Control Lists (ACLs) to allow only trusted IP addresses.
- Enable DNSSEC (DNS Security Extensions) to protect DNS data integrity.
- Regularly monitor DNS logs for suspicious activity.
- Keep DNS server software updated with the latest security patches.
- Conduct periodic DNS security assessments and audits.
- Remove unnecessary DNS records and maintain proper DNS configurations.

Conclusion

A successful DNS Zone Transfer exposes critical information about an organization's network, making it easier for attackers to perform reconnaissance and launch targeted attacks. Restricting zone transfers, implementing DNSSEC, monitoring DNS activity, and maintaining secure DNS configurations are essential steps in protecting the organization's DNS infrastructure and overall cybersecurity.

